

Aula 1 (Módulo 15) — As Fases da Resposta a Incidentes

1. De onde vem um incidente

Um **incidente** (diferente de um simples alerta, Módulo 08) é um evento **confirmado** como violação de segurança real — pode chegar até aqui vindo de um alerta escalado (N1 → N2 → confirmado como TP), de uma sessão de Threat Hunting (Módulo 14) que encontrou algo real, ou até de um relato externo (um cliente avisando, um pesquisador reportando).

2. As sete fases (modelo usado neste curso)

Preparation → Identification → Triage → Containment → Eradication →
Recovery → Lessons Learned

Esse modelo (às vezes chamado de **PICERL**, popularizado pelo SANS Institute) é uma expansão do modelo oficial de 4 fases do NIST SP 800-61 (Preparation; Detection and Analysis; Containment, Eradication and Recovery; Post-Incident Activity) — os dois dizem essencialmente a mesma coisa, com granularidade diferente. Vamos seguir as sete fases detalhadas.

Preparation — antes de qualquer coisa acontecer

Tudo que precisa estar pronto **antes** de um incidente: playbooks documentados, ferramentas configuradas (SIEM, EDR — já estudados), contatos de escalção definidos, backups testados (não só existentes — **testados**, porque um backup nunca restaurado é uma suposição, não uma garantia), e um time treinado (o motivo de você estar estudando isso agora).

Por que é a fase mais negligenciada e mais importante: a qualidade da resposta a um incidente real é determinada, em grande parte, pelo que foi preparado **antes** — improvisar tudo durante uma crise real custa tempo (e tempo, num incidente ativo, é exatamente o recurso mais escasso).

Identification — confirmando que é um incidente real

É aqui que o trabalho dos Módulos 08 e 14 desemboca: um alerta ou achado de hunting é confirmado como incidente. Nesta fase, o objetivo é responder: **o que aconteceu, quando começou, e qual o escopo inicial conhecido** (mesmo que incompleto ainda).

Triage — priorizando entre múltiplos incidentes

Diferente da triagem de alerta (Módulo 08, que decide TP/FP), esta triagem acontece **depois** de já confirmado como incidente real — é sobre **priorizar** quando existem múltiplos incidentes competindo por atenção ao mesmo tempo (lembra da fórmula de priorização do Módulo 08, Aula 2: severidade × confiança × criticidade do ativo).

Containment — parando a sangria

O objetivo da contenção é **limitar o dano**, não necessariamente remover a ameaça ainda (isso vem na próxima fase). Duas abordagens comuns:

- **Contenção de curto prazo:** ação imediata, como isolar um host da rede (a capacidade de EDR que já mencionamos no Módulo 10) — rápida, mas pode não ser sustentável por muito tempo (o host isolado não consegue trabalhar).
- **Contenção de longo prazo:** uma solução mais duradoura, como reconstruir o sistema numa rede segmentada enquanto a investigação continua.

Uma decisão crítica nesta fase: isolar imediatamente vs. **observar um pouco mais** antes de agir, para entender melhor o escopo/técnicas do atacante (chamado às vezes de deixar o atacante "se expor mais" antes da contenção). Essa decisão envolve trade-offs reais — geralmente tomada por quem tem mais experiência/autoridade no time, não pelo N1 sozinho.

Eradication — removendo a causa raiz

Diferente de só "limpar o que apareceu" (remover um arquivo, matar um processo), erradicação busca a **causa raiz completa**: como o atacante entrou (vulnerabilidade explorada? credencial comprometida? phishing?), e remove **tudo** relacionado — incluindo persistência que ainda não foi descoberta (lembra do Cenário 4 do Módulo 10 — sempre verificar o que MAIS pode ter sido criado, não só o item óbvio).

Erro comum a evitar: declarar "resolvido" só porque o sintoma inicial sumiu, sem confirmar que a causa raiz foi eliminada — isso frequentemente resulta em **reinfecção** dias/semanas depois.

Recovery — voltando à operação normal, com segurança

Restaurar sistemas afetados à operação normal — de backups limpos (nunca reconectar um sistema comprometido "como estava"), com monitoramento **reforçado** temporariamente sobre os sistemas afetados (para pegar qualquer sinal de que a ameaça não foi completamente eliminada).

Lessons Learned — o que muitas organizações pulam, e não deveriam

Uma reunião pós-incidente (idealmente em até 1-2 semanas, enquanto ainda está fresco) para responder: o que funcionou bem? O que atrasou a resposta? Que lacuna de detecção permitiu isso acontecer sem alerta antes (conecta direto com Threat Hunting, Módulo 14, e Detection Engineering, Módulo 21)? Que mudança de processo/ferramenta é necessária?

Por que importa: um incidente sem essa etapa final é uma oportunidade de melhoria desperdiçada — a organização gasta o custo completo de responder ao incidente, mas não colhe o benefício de ficar mais resiliente para o próximo.

3. Conectando tudo

Preparation (antes)

↓

Identification (Módulo 08/14 confirmam) → Triage (prioriza entre múltiplos incidentes)

↓

Containment (limita o dano) → Eradication (remove causa raiz)

↓

Recovery (volta ao normal, com segurança e monitoramento reforçado)

↓

Lessons Learned (retroalimenta Preparation E Detection Engineering, Módulo 21, fechando o ciclo)

4. Exercício de reflexão

Retome o incidente do Módulo 13, Aula 2 (Word malicioso → PowerShell → Run key de persistência). Sem escrever a resposta agora, pense: o que você faria em cada uma das sete fases, especificamente para **esse** incidente? (Vamos aplicar isso de verdade na próxima aula.)

5. Recapitulando

- Incidente = achado **confirmado** (vindo de alerta escalado ou hunting), diferente de um simples alerta ainda não confirmado.
- Preparation é a fase mais negligenciada e mais determinante da qualidade da resposta real.
- Containment limita o dano; Eradication remove a causa raiz completa (não só o sintoma); Recovery volta ao normal com monitoramento reforçado.
- Lessons Learned fecha o ciclo, retroalimentando preparação e detecção futuras — pular essa fase desperdiça o aprendizado do incidente.

Próxima aula (fecha o Módulo 15)

Um incidente simulado completo, do início ao fim, aplicando as sete fases — e o convite para você conduzir sua própria resposta a incidente, ao vivo.

Fontes recomendadas

- **NIST SP 800-61 Rev. 2**: modelo oficial de 4 fases, já citado em módulos anteriores; base formal por trás do modelo de 7 fases usado aqui. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- **SANS Institute — Incident Handler's Handbook** (referência comunitária/educacional amplamente citada, não um padrão oficial de governo): consulte sans.org para a versão mais atual do modelo PICERL.